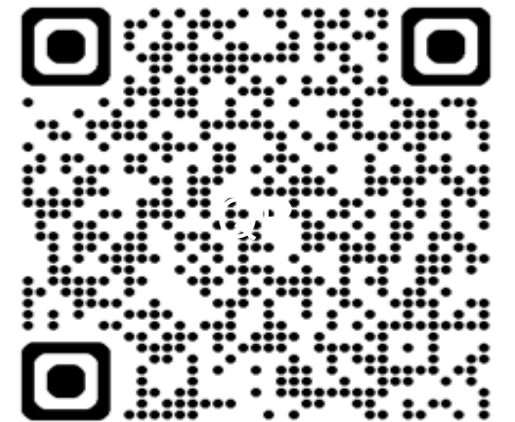


“Automotive SBOM”

2026/4/23



Mission

Accelerate **Smart** and **Effective** SBOM Usage in Automotive Industry

For this purpose, we would like to...

Identify key challenges, concerns, and barriers to effective SBOM adoption in the automotive industry

So, we decided to...

Establish a collaborative community to share and discuss best practices for SBOMs in the automotive industry

Promote awareness and position Automotive SBOM as good practices across the automotive industry

Goal

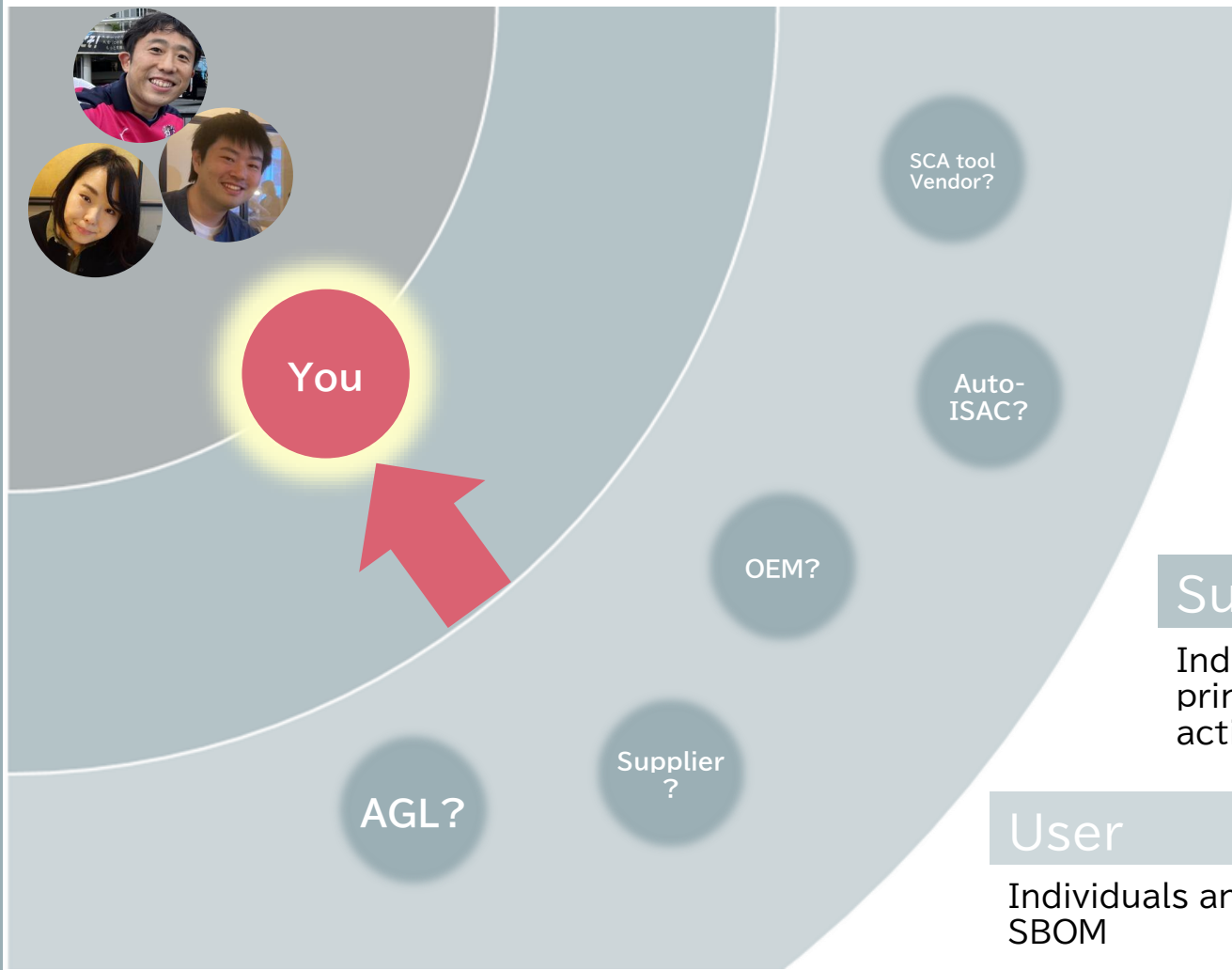
Future Goal

- Build a dynamic, collaborative community to drive the advancement of Automotive SBOMs
- Gain strong **endorsements from leading industry associations** to position Automotive SBOMs as best practices
- Establish Automotive SBOM as a **referenced standard within industry guidelines and legal requirements**

Near-Term Strategic Goal

- Increase industry awareness and drive **broader adoption** of Automotive SBOM **across the entire supply chain** (from OEMs to **Tier-N suppliers**)
- **Finalize** Automotive SBOM as the industry's best practice for smart and effective SBOM implementation, **incorporating feedback from community (you!!)**

Join us



Multiple Approaches to Support...

Contributor

Individuals and organizations actively engaged in the evaluation, advocacy, and utilization of Automotive SBOM

Supporter

Individuals and organizations that understand the principles of Automotive SBOM and support contributor activities

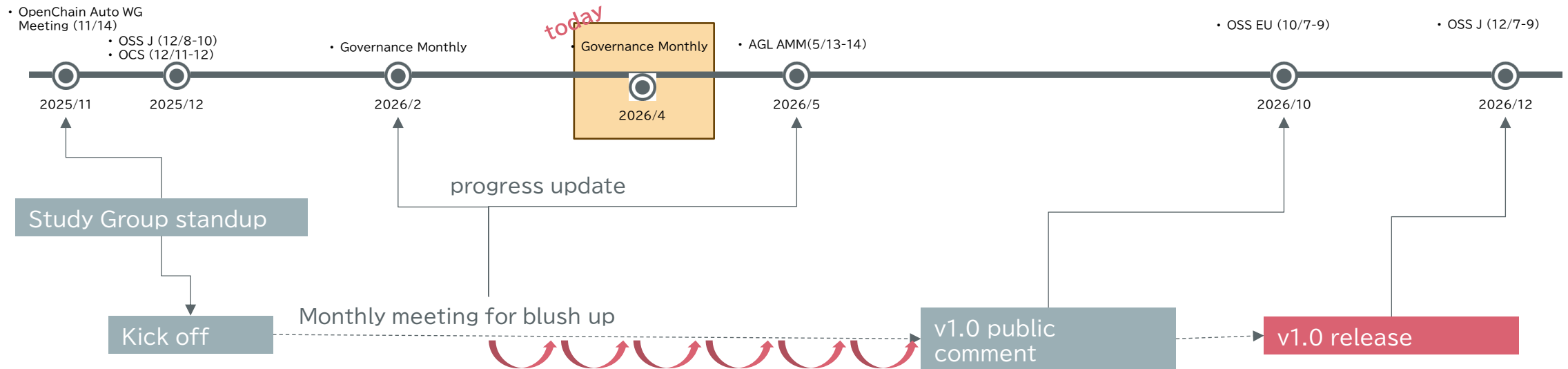
User

Individuals and organizations that adopt and leverage Automotive SBOM

Automotive SBOM Action Plan

Roadmap

Events



Actions

Key Points

from the draft of Automotive SBOM

Background

Challenges of SBOM Implementation in the Automotive Industry



Automotive SBOM

We have reconsidered the content to focus on operations in the automotive industry, and defined an Automotive SBOM as an SBOM specification that follows the general-purpose SBOM specification.

Purpose of Automotive SBOM

1 Use as a Common Standard in the Supply Chain

- Automotive SBOM defines the format, data content, and granularity of the information that OEMs requires.
- Being used in suppliers as **a common guideline for creating SBOMs that meet quality criteria**, Automotive SBOM improve transparency and traceability throughout our supply chain.

2 Contribution to Improving Productivity in the Automotive Industry

- Automotive SBOM was designed with the intention to be commonly used by OEMs both in Japan and overseas.
- By **standardizing the requirements from OEMs to suppliers**, the burden on suppliers to comply with multiple requests from OEMs will be reduced.

3 Use as a Requirement Specification for Tool Vendors

- The content of SBOM can be collected by using SCA tool, but the functions and performance of the SCA tools currently available on the market are not perfect.
- Automotive SBOM can be used as a means of **concretely communicating feature enhancement requirements** to SCA tool vendors, and as **a criterion for tool selection by each development team**.

Configuration of Automotive SBOM

Data Fields

Definition of Data Items to be Handled as SBOM

Automation Support

Definition of Document Format, Format of Each Data, and Implementation Examples

Practice and Process

Definition of Operational Procedures for Requesting, Generating, and Using SBOM

Key Points from the draft of Automotive SBOM

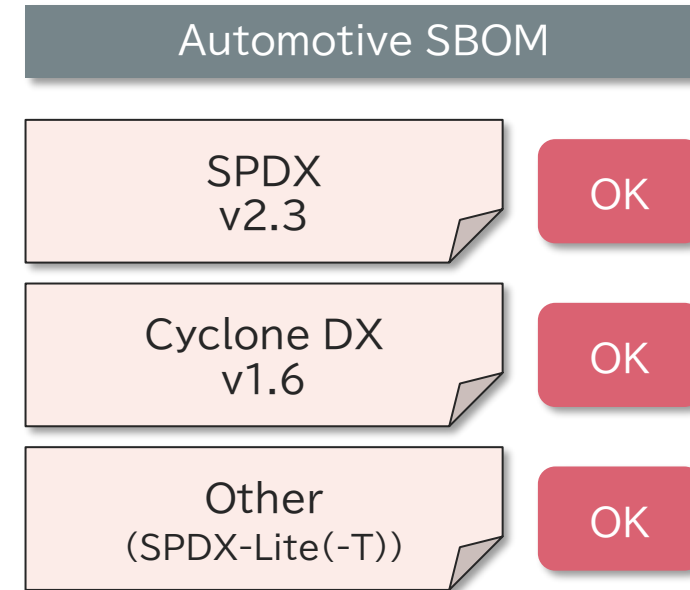
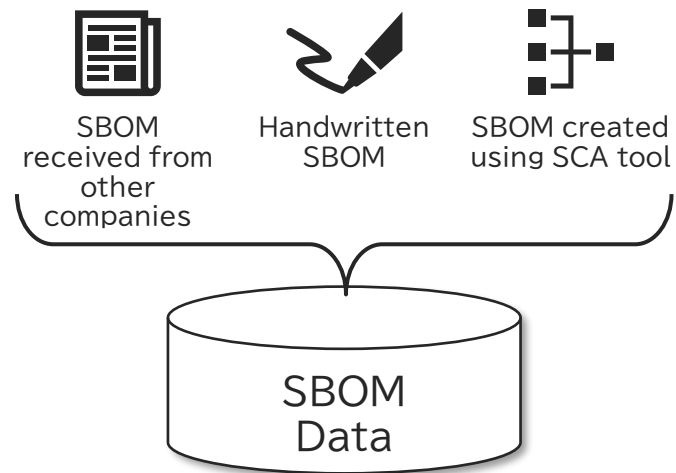
Data Fields

Data Fields

Defined as the Minimum Data Set Required to Understand the Configuration Information of the Target Software

#	Name of Data Field	Required	Description	Example
1	SBOM Metadata			
1-1	SBOM Author Name	○	Name of the entity that created the SBOM	"TOYOTA MOTOR CORPORATION"
1-2	SBOM Timestamp	○	Date and time when the SBOM was created or updated	"2025-01-24T22:31:37Z"
1-3	SBOM Type	○	Information to identify when and what types of software the SBOM was generated from	(Using SBOM type like "Build" etc.. which is defined by CISA at USA)
1-4	SBOM Primary Component	○	Information to identify the components that are primarily represented in the SBOM	(Express by using Component entities#2)
2	Component Attribute			
2-1	Component Name	○	Name of the component	"Apache Tomcat"
2-2	Component Version	○	Version information of the component	"10.0.5"
2-3	Component Supplier Name	○	Name of the entity that provided the component	Woven by Toyota, Inc.
2-4	Component Relationship	○	Information to identify dependencies between components	(Express following document format)
2-5	Component Unique Identifier	○	Information to uniquely identify the component	"pkg:github/apache/tomcat"
2-6	Component File Name	-	Name of the file of the component	"tomcat-10.0.5.tar.gz"
2-7	Component Download Location	-	URL from which the component is downloaded	"https://github.com/apache/tomcat/...../10.0.5.tar.gz"
2-8	Component Declared License	-	License declared by the component's author	Apache-2.0"
2-9	Component Concluded License	○	License that the SBOM author concluded applies to the component	"Apache-2.0"
2-10	Component Cryptographic Hash	-	Hash value of the component	"SHA256: 525.....5a8"
2-11	Component Copyright Notice	○※	Copyright notice attached to the component	"Copyright © 1999-2022, The Apache Software Foundation"
2-12	Component External Document References	○	Information for external references to other SBOM documents	(Express following document format)

Recommended Data Format

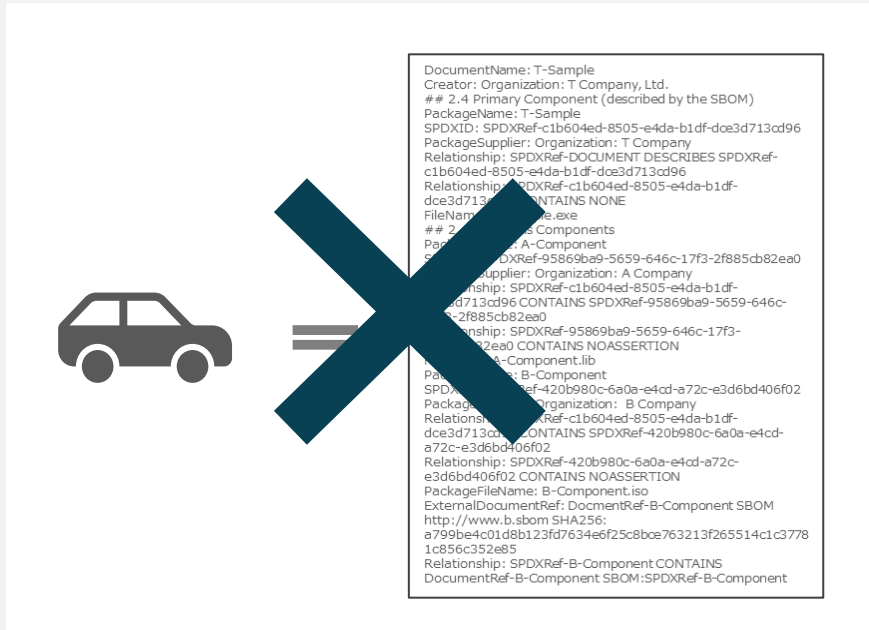
**Automation
Support**

Any format is acceptable as long as it adheres to the Automotive SBOM data fields and practices and processes

Practice and Process

Practice and Process

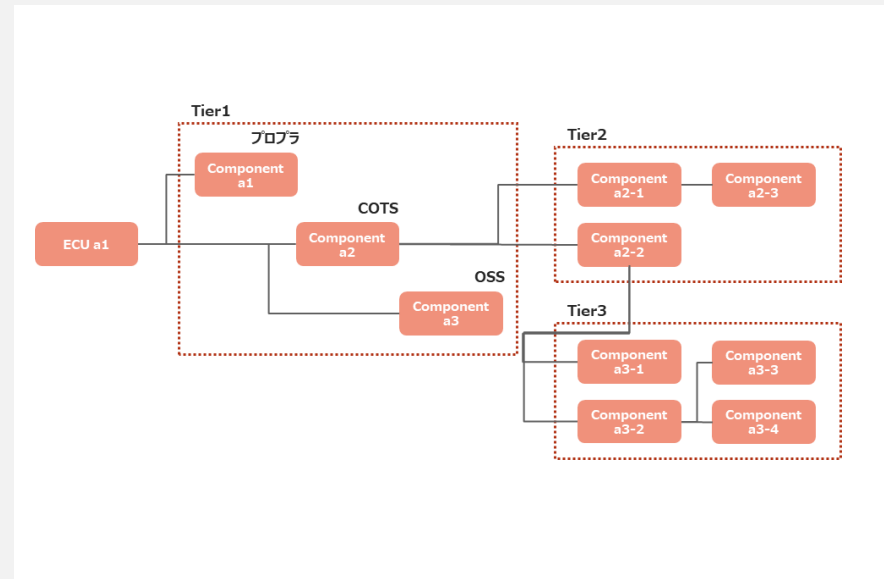
In a Single SBOM File



Disadvantages

- SBOM file becomes too large
- Time-consuming to recreate the entire SBOM file every time you update your software

Binding SBOMs Using External Reference Expressions



Advantages

- Easy to handle as a collection of small SBOMs
- High maintainability as there is no need to recreate the entire system every time a software update is made

Beyond OSS and VEX

SBOM management for non-OSS components and for the full vehicle software surface
— not just open-source dependencies.

Commercial / proprietary SW	How to handle closed-source components and NDA-bound data. Reduced-disclosure SBOM profiles may be needed.
------------------------------------	--

AI / ML models	Model cards, training datasets, and weights as SBOM entries — aligning with emerging AI BOM practice.
-----------------------	---

Hardware-linked SW	Firmware, microcode and HW–SW dependencies — linking to HBOM for the hardware side.
---------------------------	---

Cloud & backend	Connected services outside the car also ship with the product — SaaS BOM considerations.
----------------------------	--

Beyond VEX	CSAF advisories, SSVC for triage priority, and patch timing guidance.
-------------------	---

Regulations

Where SBOM meets cybersecurity management, software updates, and type-approval evidence.

UN R155 · CSMS	Demonstrate cyber risk management across the full vehicle lifecycle.
UN R156 · SUMS	Managed software updates, including OTA, with documented evidence.
ISO/SAE 21434	Cybersecurity engineering process for road vehicles — threat analysis and risk.
China & US rules	Connected-vehicle restrictions — data, component origin, and foreign-adversary rules.
Data privacy	GDPR and regional data rules for connected data flows.
Cyber Resilience Act	The Cyber Resilience Act requires products with digital elements to meet cybersecurity and vulnerability management requirements throughout their lifecycle.

AI-driven development & OSS risk

Generative AI and coding agents make unintended OSS contamination more likely
— existing SCA tooling is not enough.

The problem

AI-generated code may include OSS snippets without clear origin or license.

SCA is almost mandatory

Running an SCA tool is the baseline of self-defense — but not 100% accurate.

Snippet matching

Source-level matching helps, but accuracy is lower than dependency analysis; forks break version identification.

Tool vendor liability

Vendors cannot take responsibility for missed OSS — the industry needs a shared landing point.

Possible practice

Avoid snippet reuse in embedded dev; add prompt rules in AI-driven dev to reject snippet injection.

Unique package identification

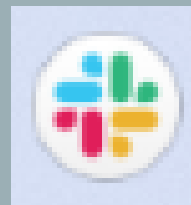
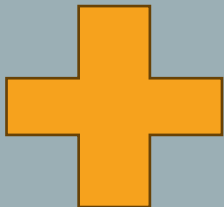
Without a reliable way to identify packages, CVE matching and VEX references stay unreliable.

IDENTIFIER LANDSCAPE

CPE	Long-standing NVD identifier; coverage gaps, slow updates.
purl	Package URL — complements CPE, ecosystem-aware, gaining ground.
SWID	ISO/IEC 19770 tags; limited adoption in OSS ecosystems.
hash / OmniBOR	Content-based IDs for forks, vendored code & snippets.

Documents

Feel free to comment and feedback here!!





Mission

Accelerate **Smart** and **Effective** SBOM Usage in Automotive Industry



Multiple Standards Cause Confusion



Industry Specific Business Practices and Development Methods



Study is still in Progress

Establish a **collaborative community** to identify and discuss **challenges**, **concerns**, and **barriers** together. And share **Best practices for SBOMs** in the automotive industry.

Goal

Future Goal

Clear SBOM Guidelines includes **OSS**, **proprietary**, **other** for the Automotive Industry – Empowering OEMs and Suppliers, SCA tool vendor to Drive Safe, Secure SDVs **Beyond Regulatory Compliance**

Near-Term Strategic Goal

- Expand SBOM awareness and adoption across the **entire automotive supply chain**.
- Incorporate community feedback** to finalize Automotive SBOM as the industry's best practice for smart, effective implementation with **you!!**

Approach

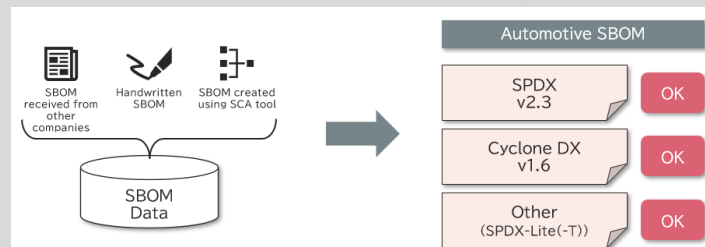
Data Fields

Data Items to be Handled as SBOM

#	Name of Data Field	Required	Description	Example
1	SBOM Metadata			
1-1	SBOM Author Name	O	Name of the entity that created the SBOM	"TOYOTA MOTOR CORPORATION"
1-2	SBOM Timestamp	O	Date and time when the SBOM was created or updated	"2025-01-24T22:31:37Z"
1-3	SBOM Type	O	Information to identify when and what types of software the SBOM was generated from	Using SBOM type like "Build" etc., which is defined by CISA at USA
1-4	SBOM Primary Component	O	Information to identify the components that are primarily represented in the SBOM (Express by using Component entities#2)	
2	Component Attributes			
2-1	Component Name	O	Name of the component	"Apache Tomcat"
2-2	Component Version	O	Version information of the component	"10.0.5"
2-3	Component Supplier Name	O	Name of the entity that provided the component	Woven by Toyota, Inc.
2-4	Component Relationship	O	Information to identify dependencies between components (Express following document format)	
2-5	Component Unique Identifier	O	Information to uniquely identify the component	"id:github/apache:tomcat"

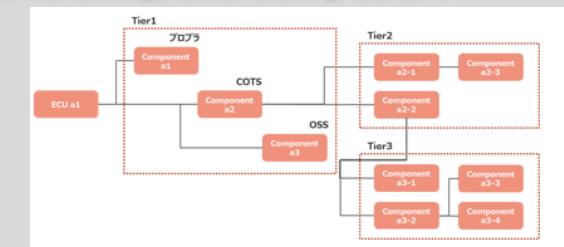
Automation Support

Document Format, Examples, SCA tool enhancement request



Practice and Process

Operational Procedures for Requesting, Generating, and Using SBOM



and more..